

15-213 秋季 20xx 实验作业 L2: 拆除二进制炸弹

布置日期: 9 月 13 日, 截止日期: 9 月 22 日

Harry Bovik (bovik@cs.cmu.edu) 是本实验的负责人。

1 简介

邪恶的 Dr. Evil 在我们的班级机器上安装了一系列“二进制炸弹”。二进制炸弹是一个由多个阶段组成的程序。每个阶段都要求你在标准输入 (stdin) 中输入特定的字符串。如果你输入了正确的字符串, 则该阶段被拆除, 炸弹进入下一阶段。否则, 炸弹会通过打印“BOOM!!!”并终止来爆炸。当所有阶段都被拆除时, 炸弹即被解除。

炸弹数量太多, 我们无法一一处理, 因此将给每位学生分配一颗炸弹进行拆除。你的任务——你不得不接受的任务——是在截止日期前拆除你的炸弹。祝你好运, 欢迎加入拆弹小组!

第一步: 获取你的炸弹

你可以通过将 Web 浏览器指向以下地址来获取你的炸弹:

```
http://$Bomblab::SERVER_NAME:$Bomblab::REQUESTD_PORT/
```

这将显示一个二进制炸弹请求表单供你填写。输入你的用户名和电子邮件地址, 然后点击“提交”按钮。服务器将构建你的炸弹, 并以名为 bombk.tar 的 tar 文件形式返回给你的浏览器, 其中 k 是你的炸弹的唯一编号。

将 `bombk.tar` 文件保存到你计划进行工作的 (受保护的) 目录中。然后执行命令: `tar -xvf bombk.tar`。这将创建一个名为 `./bombk` 的目录, 其中包含以下文件:

- README: 标识炸弹及其所有者。
- bomb: 可执行的二进制炸弹。

- bomb.c: 包含炸弹主例程以及邪恶博士友好问候语的源文件。
- writeup.{pdf,ps}: 实验说明文档。

如果由于某种原因你请求了多个炸弹，这没有问题。选择一个炸弹来攻克，并删除其余的。

第二步：拆除你的炸弹

本次实验的任务是拆除你的炸弹。

你必须在班级机器上完成这项任务。事实上，有传言说 Evil 博士确实很邪恶，炸弹在其他地方运行总会爆炸。炸弹中还内置了其他几种防篡改装置，至少我们是这么听说的。

你可以使用许多工具来帮助你拆除炸弹。请查看提示部分获取一些技巧和想法。最好的方法是使用你最喜欢的调试器逐步检查反汇编后的二进制文件。

每次你的炸弹爆炸时，它都会通知 bomblab 服务器，你将在实验的最终得分中失去 1/2 分（最多扣 20 分）。因此，爆炸炸弹是有后果的。你必须小心！

前四个阶段各值 10 分。阶段 5 和阶段 6 稍微困难一些，因此各值 15 分。所以你能获得的最高分是 70 分。

尽管各个阶段拆除难度逐渐增加，但你在逐阶段推进过程中积累的专业知识应能抵消这一难度。然而，最后一个阶段将挑战最优秀的学生，因此请勿等到最后一刻才开始。

炸弹会忽略空输入行。如果你带命令行参数运行炸弹，例如，

```
linux> ./bomb psol.txt
```

那么它将从 psol.txt 读取输入行，直到文件结束 (EOF)，然后切换到标准输入。在片刻的软弱中，Evil 博士添加了这一功能，这样你就不必反复输入已拆除阶段的解决方案。

为避免意外引爆炸弹，你需要学习如何单步执行汇编代码以及如何设置断点。你还需要学习如何检查寄存器和内存状态。完成本实验的一个附带好处是，你将非常熟练地使用调试器。这是一项关键技能，将在你未来的职业生涯中带来巨大回报。

实验安排

这是一个个人项目。所有提交均为电子形式。澄清和更正信息将发布在课程留言板上。

提交

没有明确的提交方式。炸弹会在你解题过程中自动通知老师你的进度。你可以通过查看班级排行榜来了解自己的表现，网址为：

`http://$Bomblab::SERVER_NAME:$Bomblab::REQUESTD_PORT/scoreboard`

此网页会持续更新，以显示每个炸弹的进度。

提示（请务必阅读！）

拆解炸弹的方法有很多种。你可以在不运行程序的情况下，极其细致地检查它，并准确弄清楚它的功能。这是一种有用的技巧，但做起来并不总是那么容易。你也可以在调试器下运行它，一步步观察它的行为，并利用这些信息来拆解炸弹。这可能是拆解炸弹最快的方式。

我们有一个请求，请不要使用暴力破解！你可以编写一个程序，尝试所有可能的密钥来找到正确的那个。但这并不好，原因如下：

- 每次你猜错并导致炸弹爆炸，你将被扣掉 0.5 分（最多扣 20 分）。
- 每次你猜错，都会向 bomblab 服务器发送一条消息。你可能会很快用这些消息使网络饱和，并导致系统管理员撤销你的计算机访问权限。
- 我们还没有告诉你这些字符串有多长，也没有告诉你它们包含哪些字符。即使你做了（不正确的）假设，认为它们都少于 80 个字符且只包含字母，那么每个阶段你也会有 26 种猜测。这将需要非常长的时间来运行，而且在作业截止之前你无法得到答案。

有许多工具旨在帮助你弄清楚程序是如何工作的，以及当它们不工作时问题出在哪里。以下是一些你可能在分析炸弹时觉得有用的工具列表，以及如何使用它们的提示。

- gdb

GNU 调试器，这是一个命令行调试工具，几乎在所有平台上都可用。你可以逐行跟踪程序，检查内存和寄存器，查看源代码和汇编代码（我们不会提供你炸弹的大部分源代码），设置断点，设置内存监视点，并编写脚本。

CS:APP 网站

`http://csapp.cs.cmu.edu/public/students.html`

这里有一份非常方便的 gdb 单页摘要，你可以打印出来作为参考。以下是一些使用 gdb 的其他技巧。

– 为了避免每次输入错误都导致程序崩溃，你需要学会如何设置断点。– 如需在线文档，可在 gdb 命令提示符下输入 “help”，或在 Unix 提示符下输入 “man gdb” 或 “info gdb”。有些人也喜欢在 emacs 的 gdb 模式下运行 gdb。

- `objdump -t`

这将打印出炸弹程序的符号表。符号表包含炸弹中所有函数和全局变量的名称、炸弹调用的所有函数的名称及其地址。通过查看函数名称，你可能会有所发现！

- `objdump -d`

使用此命令可以反汇编炸弹中的所有代码。你也可以只查看单个函数。

阅读汇编代码可以告诉你炸弹的工作原理。

尽管 `objdump -d` 提供了大量信息，但它并未展示全部细节。对系统级函数的调用以晦涩的形式显示。例如，对 `sscanf` 的调用可能显示为：

```
8048c36: e8 99 fc ff ff call 80488d4 <_init+0x1a0>
```

要确定该调用是针对 `sscanf` 的，你需要在 gdb 中进行反汇编。

- `strings`

该工具将显示炸弹中的可打印字符串。

在寻找某个特定工具？或者文档？别忘了，``apropos``、``man`` 和 ``info`` 这些命令是你的好帮手。特别是，``man ascii`` 可能会派上用场。``info gas`` 会提供关于 GNU 汇编器的详尽信息，远超你所需要的内容。此外，互联网也可能是一座信息宝库。如果遇到难题，随时可以向你的 instructor（讲师）寻求帮助。